TIB SYSTEMS LLC · SAP SECURITY, GRC & CONTROLS ACADEMY

The SAP Controls Career Guide

SOX, ITGC and application controls testing: what the job is, what employers ask for, and how to get ready for your first role

This guide is for people moving into SAP controls testing — junior SAP consultants, internal and external auditors, finance and accounting staff, and career changers. It explains the work in plain language, using what current job postings actually ask for. It is free, and it is not a sales brochure: most of what follows is useful whether or not you ever take a TIB course.

1. What an SAP controls tester does

Every public company has to show that its financial numbers can be trusted. When those numbers come out of SAP, someone has to prove that the system is controlled: that only the right people have access, that changes to the system are approved, that batch jobs and interfaces run completely, and that the configuration actually stops errors such as paying an invoice twice. That proof is SOX testing, and SAP controls testers produce it.

Most testers work through the same four stages every year:

Stage	What you do	Typical tools
Plan & scope	Understand the process, map risks to controls in a Risk & Control Matrix (RCM), and decide which controls are key.	RCM, walkthroughs, process narratives
Test IT general controls (ITGC)	Test access, change management and IT operations: who can do what, whether changes were approved before they moved, whether backups and jobs ran.	SUIM, PFCG, SU01, SM20, STMS / SE01, SM37, DB13
Test application & business controls (ITAC)	Prove configured controls work: three-way match, tolerances, credit holds, billing cutoff, duplicate payment checks.	SE16N, ME23N, OMR6, FB03, VKM1, VF03
Evaluate & report	Decide whether each exception is a deficiency, how serious it is, who owns the fix — and write it up so a reviewer and an auditor accept it.	Workpapers, deficiency memos, SOC reports

2. The job titles you will see

In October 2026 TIB reviewed 28 open SOX and IT audit postings on Dice — Big 4 and consultancy firms, retailers, manufacturers and technology companies. These are the titles in those postings:

- IT Auditor / Staff IT Auditor
- Senior IT Auditor
- IT Internal Auditor / Internal Audit Consultant
- Technology Audit & Advisory Manager (consultancies)
- IT SOX Governance Lead / Manager, IT SOX
- IT Audit Manager (SOX / ITGC)

Advertised pay in those postings ran roughly $80,000–$266,000 a year for permanent roles, and about $60–$75 an hour for contract roles. Most postings that showed pay were senior or manager roles; entry-level roles were less often advertised with a salary. These are ranges taken from the postings, not a promise of salary or employment. The postings repeatedly named ITGC and ITAC testing, key reports, SOC reports and the RCM — the core of section 3.

3. The eight skill areas employers ask for

Skill area	What it means in practice
Access controls	Segregation of duties at user level, joiner-mover-leaver, privileged and emergency (Firefighter) access, Fiori tile security.
Change management & operations	Transports approved before release, emergency changes, custom code, backups, interfaces and batch jobs that actually ran.
Application controls (ITAC)	Testing the configuration itself — match, tolerances, credit management, billing cutoff — not just a sample of transactions.
Populations & sampling	Pulling the complete population yourself from SAP tables, proving it is complete, and choosing a sample size you can defend.
Evidence & workpapers	Selection screen first, then result — labelled and dated; key reports (IPE) checked for completeness and accuracy.
RCM & design effectiveness	Building and reading the Risk & Control Matrix; telling a design gap from a control that failed to operate.
Deficiency evaluation	Rating findings as a deficiency, significant deficiency or material weakness, with impact, pervasiveness and compensating controls.
Judgement & communication	Explaining a finding to an auditor, an SAP developer and a CFO — and holding a correct conclusion under pressure.

4. What a normal week looks like

- **Walkthroughs:** a process owner shows you how vendor bank details get changed; you note who approves and where the evidence lives.
- **Populations:** you pull every transport released last quarter from SAP yourself, rather than accepting a list someone emails you.
- **Testing:** you check a sample of leavers were locked on or before their last day, and capture SU01 and SM20 evidence for each.
- **Exceptions:** one terminated user logged in after leaving; you trace why, what they did, and whether it matters.
- **Review notes:** your senior asks "how do you know this population is complete?" — and you answer from your workpaper, not from memory.

5. How careers usually progress

Stage	Typical focus
IT auditor / staff tester	Executing ITGC and ITAC tests, pulling populations, capturing evidence, writing workpapers.
Senior IT auditor	Owning test areas, reviewing juniors' work, handling walkthroughs and control owners.
Manager (IT SOX / technology audit)	Scoping and the RCM, sample strategy, deficiency evaluation, reporting to management and auditors.
Lead / director	Running the SOX programme, external auditor relationships, audit committee reporting.

6. Six interview questions to practise

Interviewers rarely ask you to recite a transaction code. They ask what you would do. Practise answering these out loud:

- The SoD report shows 41 conflicts, but 38 are "mitigated". Do you accept that? What would you check?
- Where would you get the population of terminated users — HR or SAP? Why does it matter?
- An emergency change was approved after it moved to production. Is that a finding? What severity?
- Your sample of invoices all passed three-way match. Does that prove the control works?
- How do you know a key report used as evidence is complete and accurate?
- Explain a material weakness to a CFO in one sentence, without using a T-code.

7. How to prepare — with or without a course

- **Learn the screens first:** SAP GUI, Fiori, SUIM, SE16N, PFCG in display mode, STMS. Navigation should not use up your thinking.
- **Pull your own populations:** practise extracting complete data from SAP tables and proving it is complete. Reviewers reject borrowed lists.
- **Plan before you open SAP:** write the risk, the control objective, the population source and the evidence you will capture first.
- **Practise defending a conclusion:** say your finding out loud to an imaginary auditor, developer and CFO. That is what interviews and first engagements test.
- **Keep evidence:** selection screen, result, label, date — for every exercise. It becomes a portfolio you can talk about.

8. How TIB's The Full Sweep fits in

If you want structured, live practice, TIB's course runs in two levels, taught live by an instructor on a real SAP training system, Tue · Thu · Sat · Sun, with 5 seats per class time:

- **Intermediate: Controls Testing ($950)** — 16 live sessions: access, change and operations ITGC, GRC process controls, record-to-report, procure-to-pay and order-to-cash application controls; three marked workpapers.
- **Advanced: Manager Track & Emerging Practice ($850)** — 12 live sessions: building the RCM, design effectiveness, sampling, deficiency classification, other GRC platforms, full-population analytics, AI-assisted review and Clean Core; an RCM, a deficiency memo and a stakeholder panel.
- **Both levels ($1,650)** — 28 live sessions; a certificate for each level.

Course work builds practical skill and interview readiness. It is not the same as production audit experience, and TIB does not describe it that way. TIB Systems is an independent training provider; the course is not endorsed by SAP SE.

Current start dates, class times and levels: sap-testing-course-01-home.vercel.app

Questions: academy@tib-systems.com